

Applicability & Gap Matrix

Sentinel Nexus — framework coverage, gaps, and remediation

Information Security & AI Governance

June 2026

Contents

Overview 2

Framework Applicability 3

NIST SP 800-53 Rev. 5 — Family Coverage 6

NIST AI 600-1 (GenAI Profile) 6

Outstanding Gaps (addressable) 7

Overview

For each framework taxonomy, every item is classified **Covered** (a Sentinel Nexus control addresses it), **GAP** (applicable but not yet addressed — with a remediation that *can* address it), or **N-A** (not applicable to a defensive SOC platform; see the Applicability Determinations). OWASP/ATLAS coverage is computed from the controls manifest; SP 800-53 titles are the authoritative NIST OSCAL rev5 catalog.

Framework Applicability

OWASP Top 10 for Large Language Model Applications (2023)

Covered 9 · Gaps 1 · N-A 0

ID	Item	Status	Controls	Remediation (if gap)
LLM01	Prompt Injection	Covered	SEC-CANARY, SEC-SANITIZER	—
LLM02	Insecure Output Handling	Covered	SEC-DUCKDB-SANDBOX, SIEM-TOOL-GUARD	—
LLM03	Training Data Poisoning	Covered	SEC-RLHF-QUARANTINE, SEC-TRAINING-HYGIENE, SEC-VECTOR-DIM	—
LLM04	Model Denial of Service	Covered	SEC-MODEL-DOS	—
LLM05	Supply Chain Vulnerabilities	Covered	SEC-FAILOVER	—
LLM06	Sensitive Information Disclosure	Covered	SEC-DLP-EGRESS	—
LLM07	Insecure Plugin Design	Covered	SEC-OUTPUT-SCHEMA	—
LLM08	Excessive Agency	Covered	SEC-BLAST-RADIUS, SEC-DUCKDB-SANDBOX, SEC-OUTPUT-SCHEMA, SIEM-TOOL-GUARD	—
LLM09	Overreliance	Covered	AI-REVIEW-BOARD, SEC-REGRESSION-GATE	—

ID	Item	Status	Controls	Remediation (if gap)
LLM10	Model Theft	GAP	—	Addressable: rate-limit + anomaly-monitor the sovereign inference endpoints and add model-extraction / membership-inference detection; tighten access control and egress monitoring on weight artifacts. SHA-384 verification protects weight INTEGRITY (tampering) but not exfiltration/theft.

MITRE ATLAS — platform-relevant techniques

Covered 6 · Gaps 2 · N-A 1

ID	Item	Status	Controls	Remediation (if gap)
AML.T0042	Verify Attack (prompt-leak tripwire defended)	Covered	SEC-CANARY	—
AML.T0043	Craft Adversarial Data	Covered	SEC-REGRESSION-GATE, SEC-SANITIZER	—
AML.T0015	Evade ML Model	Covered	SEC-REGRESSION-GATE	—
AML.T0044	Full ML Model Access (weight tampering)	Covered	SEC-SUPPLY-CHAIN	—
AML.T0031	Erode ML Model Integrity (reward poisoning)	Covered	SEC-RLHF-QUARANTINE	—
AML.T0020	Poison Training Data	Covered	SEC-RLHF-QUARANTINE, SEC-TRAINING-HYGIENE	—

ID	Item	Status	Controls	Remediation (if gap)
AML.T0024	Exfiltration via ML Inference API (model extraction)	GAP	—	Addressable: detect model-extraction query patterns + membership inference on the internal vLLM endpoints (rate/volume anomaly + canary outputs). Ties to OWASP LLM10 and NIST MS-2.10-001 (POA&M-4).
AML.T0040	ML Model Inference API Access	GAP	—	Addressable: enforce authn/z + per-caller quotas on the sovereign inference endpoints and log/alert on abnormal query volume (currently network-isolated but not rate-monitored).
AML.T0048	Societal Harm	N-A	—	Defensive internal SOC system; not a public content generator (see applicability determinations).

NIST SP 800-53 Rev. 5 — Family Coverage

Authoritative control titles from NIST OSCAL v1.4.0.

Family	Title	Controls referenced
AC	Access Control	AC-17, AC-3, AC-4, AC-6, AC-7
AU	Audit and Accountability	AU-12, AU-2, AU-3, AU-6, AU-9
CA	Assessment, Authorization, and Monitoring	CA-2, CA-7
CM	Configuration Management	CM-2, CM-3, CM-7
CP	Contingency Planning	CP-10
IA	Identification and Authentication	IA-5
RA	Risk Assessment	RA-3
SC	System and Communications Protection	SC-16, SC-28, SC-5, SC-6, SC-7, SC-8
SI	System and Information Integrity	SI-10, SI-12, SI-16, SI-3, SI-4, SI-7
SR	Supply Chain Risk Management	SR-11, SR-3, SR-4

NIST AI 600-1 (GenAI Profile)

The 12 GAI risk families and their coverage/gaps are maintained in ../nist_ai_600_1_control_tracker.md §1 (e.g. Confabulation, Bias/Homogenization, and Value-Chain are the active high-exposure areas; CBRN/CSAM/violent/IP are N-A per the Applicability Determinations).

Outstanding Gaps (addressable)

These are **applicable** items not yet covered by a control, each with a remediation that can close it. They are candidate backlog items.

- **LLM10 — Model Theft.** Addressable: rate-limit + anomaly-monitor the sovereign inference endpoints and add model-extraction / membership-inference detection; tighten access control and egress monitoring on weight artifacts. SHA-384 verification protects weight INTEGRITY (tampering) but not exfiltration/theft.
- **AML.T0024 — Exfiltration via ML Inference API (model extraction).** Addressable: detect model-extraction query patterns + membership inference on the internal vLLM endpoints (rate/volume anomaly + canary outputs). Ties to OWASP LLM10 and NIST MS-2.10-001 (POA&M-4).
- **AML.T0040 — ML Model Inference API Access.** Addressable: enforce authn/z + per-caller quotas on the sovereign inference endpoints and log/alert on abnormal query volume (currently network-isolated but not rate-monitored).

Theme. The principal residual exposure is **inference-endpoint abuse / model extraction** (OWASP LLM10, ATLAS AML.T0024 / AML.T0040, NIST MS-2.10-001): the sovereign vLLM endpoints are network-isolated but not rate-/anomaly-monitored for extraction or membership-inference query patterns. Remediation is a bounded, testable control (per-caller quotas + query-volume anomaly alerting + a membership-inference review) — tracked as a backlog item and SSP POA&M-4.